

Estrutura Normativa – Nível Estratégico, Tático e Operacional

Objetivo da Aula

Compreender a estrutura hierárquica da segurança da informação em uma empresa, explorando os níveis Estratégico, Tático e Operacional.

Apresentação

Nesta jornada, exploraremos a grande importância da Política de Segurança da Informação (POSIC) e sua estrutura hierárquica. A capacidade de proteger dados sensíveis, informações críticas e sistemas contra ameaças é fundamental para a confiança dos clientes, a conformidade regulatória e a continuidade dos negócios. Ao longo desta aula, você descobrirá como a POSIC é muito mais do que um simples documento; ela é a espinha dorsal que guia decisões, ações e responsabilidades em toda a organização.

Dividida em três níveis distintos – Estratégico, Tático e Operacional –, nossa exploração destaca os papéis cruciais de cada um na salvaguarda da informação. Compreender essa estrutura hierárquica é essencial para a implementação bem-sucedida da POSIC e para a construção de uma cultura de segurança eficaz. Acompanhe-nos enquanto mergulhamos nesse mundo complexo, mas essencial, da segurança da informação nas organizações modernas.

1. Estrutura Hierárquica da Segurança da Informação

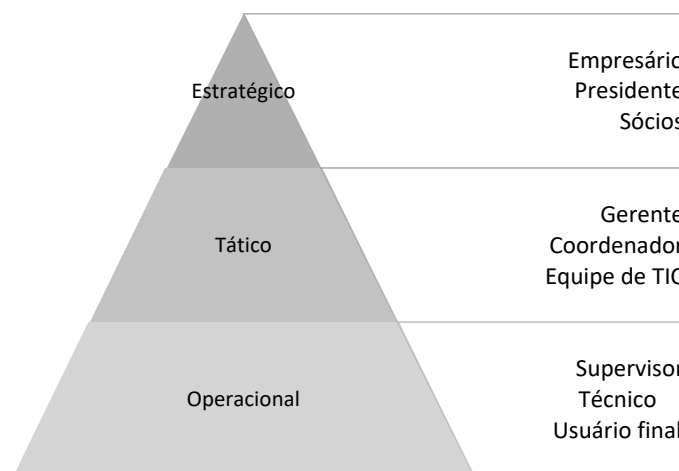
A capacidade de proteger dados sensíveis, informações críticas e sistemas contra ameaças crescentes é vital para a confiança dos clientes, a conformidade regulatória e a continuidade dos negócios. Para alcançar essa segurança de maneira eficaz e abrangente, as organizações adotam a POSIC. Esta abordagem estruturada garante os princípios de segurança: integridade, disponibilidade e confidencialidade.

A POSIC é muito mais do que um simples documento; ela é a espinha dorsal que orienta as decisões, ações e responsabilidades relacionadas à segurança da informação em toda a organização. Uma parte essencial dessa política é a sua estrutura hierárquica, que define claramente os níveis de responsabilidade e ação em todos os setores da empresa.

Esta aula explora essa estrutura normativa em profundidade, destacando como ela se divide em três níveis distintos, cada um desempenhando um papel vital na salvaguarda da informação.

No nível mais alto, encontramos a alta administração, encarregada de estabelecer as diretrizes estratégicas e garantir que a POSIC esteja alinhada com os objetivos de negócios (vide figura 9). No nível tático, gerentes e equipes de TI traduzem essas diretrizes em ações práticas, desenvolvendo planos e monitorando a implementação. E, no nível operacional, os usuários finais, representando todas as partes da organização, desempenham um papel ativo na execução das políticas de segurança no dia a dia.

Figura 1: Estrutura Hierárquica



Fonte: UNIFAP. Disponível em: <https://www2.unifap.br/glauberpereira/files/2015/03/Planejamento-Estrat%C3%A9gico.pdf>. Acesso em: 1º fev. 2024. Adaptado de

A compreensão dessa estrutura hierárquica é essencial para a implementação bem-sucedida da POSIC e para a construção de uma cultura de segurança eficaz. Portanto, embarque nesta jornada conosco enquanto exploramos a estrutura normativa que molda a segurança da informação nas organizações modernas.

1.1. Nível Estratégico (Alta Administração)

O nível estratégico, que envolve a alta administração de uma organização, desempenha um papel crucial na construção de uma base sólida para a segurança da informação. Este nível é a base fundamental das iniciativas de segurança, uma vez que estabelece a direção geral e o comprometimento com a proteção de informações e ativos valiosos. Vamos explorar as responsabilidades e funções-chave desse nível estratégico na Política de Segurança da Informação (POSIC).

A alta administração assume a responsabilidade de definir as diretrizes estratégicas da POSIC. Isso vai além de simplesmente reconhecer a importância da segurança da informação; envolve a criação de uma visão clara e abrangente. Nesse sentido, a alta administração determina os objetivos de segurança da informação que a organização busca alcançar. Esses objetivos podem variar de acordo com a natureza da organização e seu setor, mas envolvem geralmente a proteção de dados confidenciais, a garantia da integridade dos sistemas e a disponibilidade contínua de serviços essenciais. Além disso, a alta administração também considera a alocação de recursos financeiros, humanos e tecnológicos necessários para atingir esses objetivos.

A aprovação da POSIC é um passo crítico realizado pela alta administração. Isso significa que a política não é apenas uma diretriz abstrata, mas um documento oficial que deve ser seguido por toda a organização. A alta administração assegura que a POSIC esteja em total conformidade com os objetivos de negócios e a estratégia global da organização. Essa aprovação fornece a validação necessária para que a política seja implementada com a máxima autoridade.

A alta administração é responsável por alocar os recursos necessários para tornar a POSIC uma realidade. Isso pode envolver alocar financiamento para investimentos em tecnologias de segurança, contratar pessoal especializado em segurança da informação e garantir que a organização tenha os recursos necessários para implementar medidas de segurança eficazes. Além disso, a alocação de recursos envolve o compromisso de tempo e esforço da alta administração, demonstrando a importância dada à segurança da informação e influenciando a cultura de segurança em toda a organização.

Em resumo, o nível estratégico (alta administração) desempenha um papel fundamental na definição das diretrizes gerais da Política de Segurança da Informação. É responsável por estabelecer uma visão clara, aprovar a política e alocar recursos necessários para garantir que a segurança da informação esteja alinhada com os objetivos de negócios e proteja os ativos valiosos da organização. Essa liderança estratégica é essencial para a criação de uma cultura de segurança eficaz em toda a organização.

1.2. Nível Tático (Gerentes e Equipes de TIC)

Compreendendo gerentes e equipes de TIC (tecnologia da informação e comunicação), este nível está na linha de frente da transformação das diretrizes estratégicas em ações concretas e efetivas. Neste contexto, exploraremos as funções e responsabilidades desse nível tático, destacando a importância deste nível na proteção das informações e ativos da organização.

Uma das principais responsabilidades das equipes de TIC e dos gerentes táticos é traduzir as diretrizes estratégicas da POSIC em planos e procedimentos de segurança da informação. Isso significa que eles devem desenvolver estratégias específicas para proteger os ativos de informação e os sistemas da organização. Essas estratégias podem incluir a implementação de sistemas de controle de acesso, criptografia, políticas de senha, políticas de backup, entre outras medidas. Uma vez que esses planos são desenvolvidos, essas equipes são encarregadas de supervisionar a implementação eficaz dessas medidas em toda a organização.

A segurança da informação não se limita apenas à implementação de medidas; o monitoramento contínuo é igualmente crucial. Nesse nível tático, as equipes de TIC são responsáveis por monitorar a eficácia das medidas de segurança em vigor. Isso envolve a identificação de eventuais vulnerabilidades e a detecção de incidentes de segurança, como tentativas de acesso não autorizado, malware ou outras ameaças. Além disso, essas equipes são encarregadas de preparar relatórios detalhados sobre a situação da segurança para apresentar à alta administração. Esses relatórios são essenciais para a tomada de decisões informadas em relação à segurança.

A segurança da informação é um esforço coletivo que depende de todos os membros da organização. Nesse contexto, o nível tático desempenha um papel fundamental na garantia de que os funcionários sejam devidamente treinados e conscientizados sobre as políticas e práticas de segurança. Isso inclui a promoção da educação em segurança, a condução de treinamentos regulares e a realização de simulações de incidentes. O objetivo é capacitar os funcionários a reconhecerem ameaças potenciais, entenderem a importância de cumprir as políticas de segurança e saberem como reagir adequadamente em caso de incidentes.

Em resumo, o nível tático é responsável pela tradução das diretrizes estratégicas da POSIC em ações concretas. Eles desenvolvem planos, supervisionam a implementação, monitoram a eficácia das medidas, identificam vulnerabilidades e incidentes, e garantem que os funcionários sejam devidamente treinados e conscientizados em segurança. O sucesso da implementação de um ambiente seguro e na execução da POSIC depende largamente dos esforços dos funcionários deste nível.

1.3. Nível Operacional (Usuários Finais)

Foi dada a partida, os dados estão lançados, resta somente executar os planos desenvolvidos previamente. O nível operacional representa a implementação prática e a execução das políticas de segurança. Os usuários finais, que podem ser funcionários de todos os departamentos da organização, desempenham um papel essencial na manutenção de um ambiente seguro. Nesse nível, destacamos as responsabilidades e a importância dos usuários finais na proteção das informações e ativos da organização.

Os usuários finais são a linha de frente na execução das políticas de segurança da informação no contexto do trabalho diário. Isso significa que eles desempenham um papel ativo na aplicação de práticas seguras no uso de sistemas, na manipulação de dados sensíveis e na comunicação segura. Isso envolve a utilização de senhas seguras, a proteção de dispositivos e a adoção de boas práticas de segurança ao manusear informações sensíveis. Eles são os agentes que garantem que as políticas estabelecidas no nível estratégico e tático sejam efetivamente aplicadas em todas as atividades cotidianas.

Os funcionários deste nível devem estar cientes de como relatar incidentes de segurança. Isso inclui incidentes como a perda de dispositivos, violações de dados, atividades suspeitas e qualquer outra situação que possa representar uma ameaça à segurança da informação. O relato oportuno de incidentes é essencial para que as equipes de TIC possam responder de maneira eficaz, mitigar riscos e tomar medidas corretivas. A colaboração dos usuários finais nesse aspecto é fundamental para uma resposta rápida e eficiente.

Não apenas responsáveis por seguir políticas, o nível tático também é responsável por colaborar ativamente com as equipes de TIC na manutenção de um ambiente seguro. Isso envolve a utilização de senhas seguras e práticas de autenticação, a atualização regular de software e sistemas para corrigir vulnerabilidades conhecidas e a adoção de boas práticas de segurança ao lidar com informações sensíveis. Além disso, eles devem estar cientes da importância da segurança da informação e ser parceiros proativos na proteção dos ativos da organização.

Ou seja, o nível operacional, representado pelos usuários finais, desempenha um papel ativo na implementação das políticas de segurança da informação. Eles aplicam práticas seguras em seu trabalho diário, relatam incidentes, colaboram com as equipes de TIC e desempenham um papel fundamental na manutenção de um ambiente seguro. Sua conscientização e cooperação são essenciais para o sucesso da POSIC e para a proteção dos ativos de informação da organização.

2. Integração da POSIC com a Estratégia de TIC

Para ser verdadeiramente eficaz, a integração da POSIC com a estratégia de Tecnologia da Informação e Comunicação (TIC) da organização desempenha um papel crítico na proteção dos ativos de informação da organização. Essa integração não apenas garante que a segurança da informação seja abordada de maneira abrangente, mas também que a estratégia de segurança esteja alinhada com os objetivos de negócios mais amplos.

A POSIC não pode ser considerada uma entidade isolada. Ela deve ser desenvolvida de forma a atender aos objetivos de negócios da organização. A segurança da informação é um meio para alcançar esses objetivos, não um fim em si mesma. Isso significa que as políticas e práticas de segurança devem ser moldadas para apoiar e fortalecer a missão e os objetivos da organização. Essa integração garante que a segurança não seja vista como uma barreira, mas, sim, como um habilitador do sucesso organizacional.

A estratégia de segurança deve estar em harmonia com as tecnologias utilizadas pela organização. Isso envolve a seleção e implementação de soluções de segurança que estejam alinhadas com os sistemas, aplicativos e infraestrutura de TIC. A tecnologia desempenha um papel crucial na proteção da informação, e a estratégia de segurança deve garantir que as ferramentas e sistemas escolhidos sejam eficazes na mitigação de ameaças e na conformidade com os padrões de segurança.

A segurança da informação não é uma camada separada, mas, sim, um componente integrado nas operações diárias de TIC. Isso inclui a incorporação de práticas de segurança desde o desenvolvimento de aplicativos até a administração de redes e sistemas. Os processos operacionais devem ser projetados com a segurança em mente, garantindo que os riscos sejam minimizados em cada etapa.

O ambiente de ameaças e a tecnologia estão em constante evolução. Portanto, a estratégia de segurança deve incluir uma avaliação contínua de riscos e ameaças. Isso envolve a adaptação à medida que novas vulnerabilidades surgem e a atualização das práticas de segurança de acordo com as mudanças no cenário de ameaças. A avaliação contínua é fundamental para manter a eficácia da POSIC ao longo do tempo.

Em resumo, a integração da POSIC com a estratégia de TIC da organização é fundamental para uma abordagem eficaz da segurança da informação. Isso requer o alinhamento com objetivos de negócios, a consideração de tecnologia, a adoção de práticas de segurança em operações de TIC e a avaliação contínua de riscos. Essa abordagem assegura que a segurança da informação seja uma parte integrante da cultura organizacional e contribua para o sucesso geral da organização.

3. Treinamento e Desenvolvimento de Funcionários

Considerando que todos os níveis hierárquicos da estrutura da POSIC podem incluir funcionários não familiarizados com práticas de TIC, o treinamento e o desenvolvimento de pessoal é fundamental para o sucesso da POSIC. A implementação bem-sucedida da POSIC depende, em grande parte, da conscientização, educação e preparação contínua dos funcionários. Neste contexto, abordaremos a importância crítica do treinamento e desenvolvimento de pessoal para atender às diretrizes da política de segurança.

Conscientizar os funcionários sobre as políticas e práticas de segurança é o primeiro passo para criar uma cultura de segurança eficaz. Os programas de treinamento não apenas transmitem conhecimento sobre ameaças e práticas seguras, mas também enfatizam a importância do cumprimento das políticas de segurança. Os funcionários precisam entender que desempenham um papel fundamental na proteção das informações da organização.

A segurança da informação é uma disciplina em constante evolução, devido ao cenário de ameaças em constante mutação. Portanto, os programas de treinamento contínuo são essenciais para manter os funcionários atualizados com as últimas ameaças e melhores práticas em segurança. Isso garante que a organização esteja preparada para enfrentar os desafios emergentes e se adaptar a novas ameaças.

As simulações de incidentes são uma ferramenta valiosa para preparar os funcionários para responder eficazmente a situações de segurança real. Elas ajudam a testar os processos de resposta a incidentes, aprimorar a capacidade de ação rápida e melhorar a colaboração entre equipes. Através dessas simulações, os funcionários podem adquirir a experiência necessária para enfrentar incidentes reais com confiança.

É crucial que os funcionários entendam que têm uma responsabilidade pessoal na proteção das informações da organização e na conformidade com a POSIC. A conscientização de que cada ação individual pode impactar a segurança global da organização é essencial. Isso cria uma cultura em que a segurança é incorporada ao comportamento e à atitude de cada membro da equipe.

Considerações Finais da Aula

Encerramos esta aula com uma compreensão mais profunda da estrutura hierárquica da segurança da informação. Exploramos os três níveis – Estratégico, Tático e Operacional –, e suas funções cruciais na proteção de informações e ativos organizacionais. Além disso, enfatizamos a integração da POSIC com a estratégia de Tecnologia da Informação e a importância do treinamento e desenvolvimento de pessoal para a implementação eficaz.

É importante lembrar que a segurança da informação não é um esforço isolado, mas, sim, uma parte integrante do sucesso de uma organização. Através da estrutura hierárquica da segurança da informação, é possível criar uma cultura de segurança que permeia toda a organização, protegendo ativos valiosos e mantendo a confiança dos clientes.

Material Complementar

Artigo

Planejamento Estratégico

Apresenta o planejamento estratégico a ser desenvolvido por uma empresa.

Disponível em: <https://www2.unifap.br/glauberpereira/files/2015/03/Planejamento-Estrat%C3%A9gico.pdf>. Acesso em: 1º fev. 2024.

Referências

BRASIL. Departamento de Segurança da Informação e Comunicações da Presidência da República. **Legislação Vigente**. Disponível em: <https://www.gov.br/gsi/pt-br/dsic/legislacao>. Acesso em: 8 ago. 2023.